ESAP Clinical AI

Readiness for Saudi Hospitals

Required Registrations · Possible Issues and Solutions · Next Steps

Contents

1. Required Registrations . . . 3

Step 1 — Legal Entity or Authorised Representative . . . 3
Step 2 — Hosting Inside Saudi Arabia (CST) . . . 3
Step 3 — Cybersecurity Requirements (NCA) . . . 3
Step 4 — Personal Data Protection Registration (SDAIA) . . . 4
Step 5 — Research Ethics Approval . . . 4
Step 6 — Medical Device Approval (SFDA) . . . 4
Step 7 — Hospital Connection and Doctor Licensing . . . 4
Step 8 — Insurance Platform NPHIES (Only If Needed) . . . 5
Summary of Registrations . . . 5

2. Possible Issues and Solutions . . . 6

2.1 Keeping Patient Data Inside Saudi Arabia . . . 6
2.2 Steps for Management . . . 6
2.3 Possible Issues and What We Will Do . . . 8
2.4 Order of Registration . . . 9

3. Next Steps . . . 10

Phase 1 — Immediate Actions . . . 10
Phase 2 — Before the First Hospital Pilot . . . 10
Phase 3 — Before Full Clinical Use . . . 11

1. Required Registrations

The registrations and approvals ESAP Clinical AI requires to operate in the Kingdom, in the order they should be pursued, with the official source for each.

Notes:

- File only on the official site. The Arabic text is the legally binding version.
- Several Saudi government portals (SDAIA, NCA, NPHIES) block access from outside Saudi Arabia. Open them from a Saudi connection or VPN.
- Check each link before filing, because government URLs change. Confirm each step with Saudi legal counsel.

Step 1 — Legal Entity or Authorised Representative

Why: SFDA needs either a Saudi legal entity or a licensed Saudi Authorised Representative (AR). Hospitals contract with an entity they can register as a vendor.

1. Decide: open a local entity, **or** appoint a licensed Saudi AR.
2. Local entity: get a foreign-investment licence and commercial registration (CR).
3. AR route: sign an AR agreement with an SFDA-licensed AR company (they register us in Step 6).

Links: Ministry of Investment (MISA): https://misa.gov.sa · Saudi Business Center (CR): https://business.sa

Step 2 — Hosting Inside Saudi Arabia (CST)

Why: all patient data and AI inference must be in Saudi Arabia, on a cloud provider licensed by CST and compliant with NCA's cloud controls.

1. Choose on-prem at the hospital, or a Saudi cloud provider.
2. For a cloud provider, check its CST registration class (A/B/C) and ask for its NCA CCC compliance evidence.
3. Sign the provider's DPA and add it to our sub-processor register.
4. Deploy everything in-Kingdom (app, DB, backups, logs, AI/GPU), block non-Saudi egress, and only then update the Privacy Policy. See the hosting checklist in the next section.

Links: CST: https://www.cst.gov.sa · CST cloud regulations (PDF): https://cst.gov.sa/en/services/licensing/Documents/CCSPR2_En.pdf · NCA CCC-2:2024: https://nca.gov.sa/en/regulatory-documents/controls-list/ccc/

Step 3 — Cybersecurity Requirements (NCA)

Why: hospitals flow NCA ECC/CCC down to vendors and will audit us against them. This step is a self-assessment we evidence to the hospital, not a registration.

1. Download ECC-2:2024 and CCC-2:2024.
2. Close our gaps (encryption at rest, audit log, MFA, lockout, backups, policies).
3. Commission an external penetration test and keep the report for hospital reviews.

Links: ECC-2:2024 (PDF): https://cdn.nca.gov.sa/api/files/public/upload/86e09090-44e4-481f-bc28-355673607654_ECC--2024-EN.pdf · CCC-2:2024 (PDF): https://cdn.nca.gov.sa/api/files/public/upload/6d5408a3-d8e6-4e96-963b-2c7198e5b7c2_CCC-2-2024-EN-.pdf · NCA: https://nca.gov.sa

Step 4 — Personal Data Protection Registration (SDAIA)

Why: health data is sensitive data. SDAIA's National Data Governance Platform holds the national register of controllers, DPO records, impact-assessment tools and breach notifications.

1. Appoint a DPO.
2. Appoint our representative on the platform, then register ESAP where we act as **controller** (website, individual accounts). For hospital patient data the **hospital** is the controller; confirm with counsel whether ESAP also registers as a processor.
3. Record the DPO's details on the platform.
4. Complete the DPIA and keep the record of processing current.
5. Use the platform for breach notification when needed (within 72 h).

Links: National Data Governance Platform: https://dgp.sdaia.gov.sa · SDAIA (PDPL, Implementing Regulations, transfer rules, NDMO standards): https://sdaia.gov.sa

Step 5 — Research Ethics Approval

Why: using real Saudi patient data to validate and recalibrate the models is research, so it needs a registered ethics committee's approval.

1. Agree the silent-pilot protocol with the partner hospital (outputs not shown to clinicians).
2. Submit to the **hospital's local IRB**, which must be registered with NCBE.
3. Get a data-sharing agreement signed alongside the approval.

Links: NCBE (under KACST): https://www.kacst.gov.sa. In practice you file through the partner hospital's IRB office.

Step 6 — Medical Device Approval (SFDA)

Why: our clinical models are very likely medical-device software. Outputs may not inform patient care until SFDA grants marketing authorisation (MDMA).

1. Book a pre-submission consultation with SFDA (via a regulatory consultant) to confirm SaMD status and risk class.
2. On the **GHAD** system, register the establishment and the Authorised Representative licence (or our local entity).
3. Build the technical file per MDS-REQ 1 and the AI/ML guidance MDS-G010: QMS (ISO 13485), risk file (ISO 14971), software lifecycle (IEC 62304), clinical evidence from the silent pilot, cybersecurity file, Arabic labelling.
4. Submit the MDMA application on GHAD, then answer SFDA's questions.
5. After approval, run post-market surveillance and report model changes and incidents through GHAD.

Links: GHAD system: https://ghad.sfda.gov.sa · MDMA requirements, MDS-REQ 1 (PDF): https://www.sfda.gov.sa/sites/default/files/2021-12/REQ1En.pdf · AI/ML guidance MDS-G010: https://www.sfda.gov.sa/en/regulations/87661 (this page returned "not found" when tested; search sfda.gov.sa for "MDS-G010" if it fails) · SFDA: https://www.sfda.gov.sa

Step 7 — Hospital Connection and Doctor Licensing

Why: the hospital must be able to connect us to its HIS, and Saudi clinicians are licensed by SCFHS, not by the US NPI.

1. Agree the interface (FHIR R4 or HL7v2) with the hospital's HIS team.
2. Verify clinician accounts against SCFHS, or create accounts only through hospital SSO.

3. Follow MOH health-data and interoperability policies the hospital points us to.

Links: SCFHS: https://scfhs.org.sa · MOH: https://www.moh.gov.sa

Step 8 — Insurance Platform NPHIES (Only If Needed)

Why: NPHIES is CHI's insurance claims and eligibility platform. We don't need it unless we start handling insurance transactions.

Links: NPHIES: https://nphies.sa · CHI: https://www.chi.gov.sa

Summary of Registrations

#	Step	Where	Link
1	Legal entity or Authorised Representative	MISA / Saudi Business Center	https://misa.gov.sa · https://business.sa
2	Licensed Saudi host	CST (+ NCA CCC)	https://www.cst.gov.sa
3	NCA controls evidence + pentest	NCA	https://nca.gov.sa
4	Controller registration + DPO	SDAIA platform	https://dgp.sdaia.gov.sa
5	Silent-pilot ethics approval	Hospital IRB (NCBE-registered)	https://www.kacst.gov.sa
6	Medical-device approval (MDMA)	SFDA GHAD	https://ghad.sfda.gov.sa
7	HIS integration + clinician licences	Hospital IT, SCFHS, MOH	https://scfhs.org.sa · https://www.moh.gov.sa
8	NPHIES (only if claims)	CHI	https://nphies.sa

2. Possible Issues and Solutions

Executive summary: we are not yet ready for a production deal with a Saudi hospital. We can start conversations and a **silent pilot** (AI runs, clinicians don't see output) once data is hosted in Saudi Arabia. We hold no Saudi Arabia certification or registration yet.

2.1 Keeping Patient Data Inside Saudi Arabia

Today the live site is on AWS in California and AI inference runs in the US/Germany. **No Saudi patient data may touch these.** To be officially hosted in Saudi Arabia:

#	What to do	How we show it is done	Official link
1	Choose the model: **on-prem at the hospital** or a **Saudi cloud provider**	Management decision recorded	—
2	Check the provider holds a **CST cloud licence** (Class A/B/C, matching the hospital's data level)	Licence certificate / CST registry entry on file	https://www.cst.gov.sa
3	Check the provider meets **NCA CCC-2:2024**, including its data-localisation rules	Provider's CCC compliance evidence on file	https://nca.gov.sa/en/regulatory-documents/controls-list/ccc/
4	Sign the contract with a **Saudi data-residency clause** + DPA (data, backups, logs, support access all in Saudi Arabia)	Signed contract + DPA	https://sdaia.gov.sa
5	Deploy **everything** in-Kingdom: app, database, backups, logs, email, **AI/LLM on a GPU**	Infra list showing a Saudi region for every component	https://cst.gov.sa/en/services/licensing/Documents/CCSPR2_En.pdf
6	Encrypt at rest with keys held in Saudi Arabia (KMS), TLS in transit	Config evidence	https://cdn.nca.gov.sa/api/files/public/upload/86e09090-44e4-481f-bc28-355673607654_ECC--2024-EN.pdf
7	Block all non-Saudi egress (allowlist); remove the US LLM default	Packet capture / egress test shows no foreign destination	—
8	Record every provider in the **sub-processor / transfer register** (country = Saudi Arabia)	Register complete	https://dgp.sdaia.gov.sa
9	Update the Privacy Policy: "Saudi patient data is stored and processed in the Kingdom" (Arabic + English)	Published only after steps 1–8	https://sdaia.gov.sa
10	Give the hospital the evidence pack: licence, CCC evidence, architecture, egress test, pentest	Hospital security sign-off	https://nca.gov.sa

2.2 Steps for Management

1. **Decide** the hosting model, DPO, and SFDA route (local entity or Authorised Representative).
2. **Host in Saudi Arabia** (table above): CST-licensed, NCA-CCC-compliant, everything in-Kingdom. https://www.cst.gov.sa
3. **Fix security gaps + pentest** against NCA ECC/CCC. https://nca.gov.sa
4. **Register with SDAIA** as controller and record the DPO. https://dgp.sdaia.gov.sa

5. **Sign paperwork** with the hospital: DPA, SLA, security questionnaire.
6. **Get ethics approval** for a silent pilot through the hospital's NCBE-registered IRB. https://www.kacst.gov.sa
7. **Register with SFDA** (GHAD → MDMA) before clinicians see AI output. https://ghad.sfda.gov.sa
8. **Go live clinically** only after MDMA, with SCFHS-verified clinicians. https://scfhs.org.sa

2.3 Possible Issues and What We Will Do

#	Area	Possible issue	What we will do	Official link
1	Data residency	Patient data or AI inference outside Saudi Arabia (today: US/Germany)	Host app, DB, backups and AI in Saudi Arabia, or on-prem at the hospital	https://www.cst.gov.sa
2	Data residency	Third-party tools (email, logging, LLM API) send data abroad	Keep a sub-processor register; use only Saudi services; block other egress	https://sdaia.gov.sa
3	PDPL	No controller registration or DPO	Appoint a DPO; register on SDAIA's platform	https://dgp.sdaia.gov.sa
4	PDPL	No explicit-consent record, DPIA or record of processing	Write the DPIA and record of processing; add consent records to the product	https://sdaia.gov.sa
5	PDPL	Breach not reported within 72 h	Breach runbook + 24 h / 72 h clocks in Ops → Incidents	https://dgp.sdaia.gov.sa
6	PDPL	Patients can't access, correct or delete data in the product	Build export, correction and deletion requests	https://sdaia.gov.sa
7	SFDA	AI counted as a medical device and used before approval	Pre-submission with SFDA; silent pilot only until MDMA is granted	https://ghad.sfda.gov.sa
8	SFDA	No Saudi entity or Authorised Representative	Open a local entity or appoint a licensed AR	https://misa.gov.sa
9	SFDA	No QMS / technical file / Saudi clinical evidence	ISO 13485 QMS, technical file per MDS-REQ 1, evidence from the silent pilot	https://www.sfda.gov.sa/sites/default/files/2021-12/REQ1En.pdf
10	NCA security	Hospital security review fails (encryption at rest, audit log, MFA, lockout)	Add encryption at rest, a tamper-proof audit log, mandatory admin MFA and login lockout	https://nca.gov.sa
11	NCA security	No pentest report or written security policies	External pentest + policy pack + backup restore test	https://cdn.nca.gov.sa/api/files/public/upload/86e09090-44e4-481f-bc28-355673607654_ECC--2024-EN.pdf
12	NCA security	Cloud provider not CST-licensed or not CCC-compliant	Pick a licensed provider and ask for CCC evidence	https://nca.gov.sa/en/regulatory-documents/controls-list/ccc/
13	Credibility	Website and pitch deck claim controls we don't have	Correct the wording to match what is built	—
14	Security hygiene	Shared demo password; leaked server password	Remove, rotate, give each person their own account	—
15	Paperwork	No DPA, SLA, security questionnaire answers or sub-processor register	Prepare and sign off the DPA, SLA and questionnaire answers	—
16	Legal pages	Privacy/Terms lack Saudi hosting, PDPL rights, SDAIA, DPO, Saudi law, Arabic	Publish the Saudi version of the text in Arabic + English	https://sdaia.gov.sa
17	Research ethics	Using hospital data without IRB/NCBE approval	Submit the silent-pilot protocol to the hospital's NCBE-registered IRB	https://www.kacst.gov.sa
18	Model quality	Models trained on US data perform worse on Saudi patients	Recalibrate + validate in the silent pilot; add Saudi fairness checks	—
19	Model quality	Open leakage alarm (Tower B) questioned by reviewers	Resolve it and document the evidence before quoting accuracy	—
20	Integration	Can't connect to the hospital's HIS (no FHIR yet)	Build FHIR R4 / HL7v2 integration with the hospital's HIS team	https://www.moh.gov.sa
21	Localisation	US codes and licences (ICD, NPI) don't fit Saudi Arabia	ICD-10-AM / SBS / SFDA drug codes; verify clinicians with SCFHS	https://scfhs.org.sa

#	Area	Possible issue	What we will do	Official link
22	Generative AI	AI text not labelled, evaluated or governed	Label AI output, build an eval set, write model cards	https://sdaia.gov.sa
23	Insurance data	Asked to handle claims/eligibility	Only then onboard to NPHIES	https://nphies.sa
24	Accreditation	Hospital asks if we are "CBAHI certified"	CBAHI accredits hospitals, not vendors; we support their survey	—

2.4 Order of Registration

1. Local entity or Authorised Representative: https://misa.gov.sa · https://business.sa
2. Licensed Saudi host (CST): https://www.cst.gov.sa
3. NCA ECC/CCC controls + pentest: https://nca.gov.sa
4. SDAIA controller registration + DPO: https://dgp.sdaia.gov.sa
5. Silent-pilot ethics approval (hospital IRB under NCBE): https://www.kacst.gov.sa
6. SFDA medical-device approval (MDMA, on GHAD): https://ghad.sfda.gov.sa
7. Clinician licences (SCFHS): https://scfhs.org.sa
8. NPHIES (only if we handle claims): https://nphies.sa

Draft for Saudi legal counsel review, not legal advice. Saudi government portals may need a Saudi connection or VPN.

3. Next Steps

What we will do, grouped by stage.

Phase 1 — Immediate Actions

#	Gap	Action	Owner
1	Website, Privacy page and pitch deck claim controls we don't have	Correct the wording to match what is built	Product
2	Shared demo password in docs; leaked server password	Remove, rotate, give each person their own demo account	Engineering
3	`care.esap.ai` is in the US	Badge it "Demo, synthetic data only"	Product
4	No DPO	Appoint an external interim DPO	Management
5	Hosting decision	Choose on-prem at the hospital or a Saudi cloud provider	Management
6	SFDA status unknown	Book an SFDA pre-submission with a regulatory consultant	Management

Phase 2 — Before the First Hospital Pilot

#	Gap	Action
7	Data outside Saudi Arabia	Deploy app, DB, backups and **LLM inference** in Saudi Arabia; egress allowlist
8	No encryption at rest	Postgres + encrypted storage + KMS in Saudi Arabia; turn on RLS
9	Audit log can be edited or deleted	Append-only + hash-chained audit table
10	MFA optional, no lockout	Enforce MFA for admins; login rate limit + lockout
11	No breach flow	Breach flag + 24 h / 72 h clocks + templates in Ops → Incidents
12	No paperwork	Sign off the DPA, SLA and security questionnaire answers; publish the sub-processor register
13	Privacy and Terms	Add the Saudi version of the text, translate to Arabic, publish after Saudi hosting is live
14	Ethics approval	IRB/NCBE pack for a **silent pilot** (outputs not shown to clinicians)
15	No security evidence	External pentest + written policy pack + backup restore test

Phase 3 — Before Full Clinical Use

#	Gap	Action
16	SFDA medical-device registration	QMS (ISO 13485), technical file, Authorised Representative, MDMA
17	Models validated on US data only	Saudi recalibration + validation from the silent pilot; resolve the Tower B leakage alarm
18	Patient rights not in product	Self-export, correction request, deletion request, DSR register for the DPO
19	Consent records	Versioned consent per purpose, with withdrawal
20	No EHR integration	FHIR R4 / HL7v2 read from the hospital HIS; Saudi ID types
21	Saudi localisation	ICD-10-AM / SBS / SFDA drug codes, SCFHS licence check, Hijri dates, Arabic notes
22	Governance gaps	NDMO classification enforced in CI; SDAIA AI-ethics + GenAI controls (labelling, eval set, model cards)
23	Retention not enforced	Scheduled purge job + deletion reports

Not needed now: NPHIES. It only matters if we ever handle insurance claims or eligibility.